

UrbanCart – ISO 27001 Compliance Program Summary

(Prepared as part of a self-directed GRC portfolio project)

UrbanCart is a small fictional e-commerce business consisting of 10 employees selling home and lifestyle products online. This compliance program covers UrbanCart's core digital assets, including its Shopify storefront, Google Workspace, AWS S3 storage, and Stripe payment integration, with a focus on protecting customer personal data (names, emails, shipping addresses, order history).

Although UrbanCart does not directly store payment card data (handled by Stripe), it still processes significant customer PII, making baseline information security controls important for maintaining customer trust and reducing breach risk.

Out of the 93 controls in ISO 27001 Annex A, I selected and reviewed 12 that were most relevant to UrbanCart's size and setup. Of these, 5 are currently **Not Implemented** and 7 are **Partially Implemented**, none are fully implemented yet. The highest-priority gaps are the absence of a written security policy (A.5.1), no formal security awareness training (A.6.3), no vulnerability management process (A.8.8), and unencrypted data storage in AWS S3 (A.8.24).

Recommended first steps are drafting a basic security policy, enforcing MFA across all business accounts, and enabling encryption on the S3 bucket. These are low-cost, high-impact fixes that would meaningfully improve UrbanCart's security posture within 30-60 days.